

Ex02 – Local Network Vulnerabilities (Resumo Explicativo e Simplificado)

1. O que é uma LAN e por que é vulnerável

Uma **LAN (Local Area Network)** é uma rede local que interliga dispositivos dentro de um espaço físico limitado, como uma escola, empresa ou casa. Apesar de normalmente protegida por firewalls e routers, a LAN ainda pode ser vulnerável a ataques vindos de dentro da própria rede.

As vulnerabilidades locais exploram falhas em protocolos internos (como ARP e DNS), más configurações ou falta de autenticação. Um atacante dentro da LAN pode interceptar, modificar ou bloquear comunicações entre dispositivos.

2. Ferramenta Incus (ambiente virtual)

O **Incus** é uma plataforma de containers Linux, semelhante ao LXD. Ele permite criar várias máquinas virtuais isoladas (como *gateway*, *client*, *server* e *mrrobot*) dentro de um único computador. Cada container simula um computador real conectado à rede.

- **Comando:** `sudo apt install incus` — instala o Incus.
- **incus launch images:debian/trixie nome** — cria um novo container Debian.
- **incus list** — mostra os containers ativos.
- **incus shell nome** — abre o terminal dentro do container.

3. Topologia criada no exercício

A rede do exercício inclui:

- **gw:** gateway que liga a LAN ao exterior (faz NAT).
- **client:** máquina vítima dentro da LAN.
- **server:** servidor legítimo.
- **mrrobot:** atacante dentro da LAN.

4. Caso 1 – Ataque ARP Spoofing

O protocolo ARP (Address Resolution Protocol) é responsável por associar endereços IP a endereços MAC na rede local. Ele não tem autenticação, o que permite que um atacante envie respostas falsas e se faça passar por outro dispositivo (por exemplo, o gateway).

Quando isso acontece, o tráfego do cliente passa a ir para o atacante, que pode interceptar ou modificar os dados. Isto é chamado de **ARP spoofing** ou **Man-in-the-Middle**.

- **Ferramenta usada:** `arp spoof` (parte do pacote `dsniff`).
- **Comando:** `arp spoof -t 192.168.2.101 192.168.2.254` — diz ao cliente que o atacante é o gateway.
- **Segundo comando:** `arp spoof -t 192.168.2.254 192.168.2.101` — diz ao gateway que o atacante é o cliente.

Para evitar ser detetado, o atacante desativa as mensagens de redirecionamento ICMP com:
`sysctl -w net.ipv4.conf.all.send_redirects=0`

5. Caso 2 – Ataque DNS Spoofing

Neste cenário, o atacante controla o **gateway** (ou servidor DNS) e altera as respostas DNS. Assim, quando o cliente tenta aceder a um site legítimo, é redirecionado para um servidor falso.

- **Ferramenta usada:** dnsmasq (servidor DNS/DHCP leve).
- **Configuração:** no ficheiro /etc/dnsmasq.conf, adicionar:
address=/services.web.ua.pt/192.168.2.103
- **Comando:** systemctl restart dnsmasq — aplica as mudanças.
- Assim, qualquer pedido ao domínio services.web.ua.pt será redirecionado ao servidor falso (fakeserver).

6. Outras ferramentas e comandos usados

- **iptables** — cria regras de firewall e NAT. Exemplo:
iptables -t nat -A POSTROUTING -o eth0 -j SNAT --to 10.255.255.254
- **dnsmasq** — fornece IPs (DHCP) e resolve nomes (DNS).
- **resolvectl flush-caches** — limpa a cache DNS do cliente.
- **Wireshark** — analisa pacotes de rede e permite observar o tráfego interceptado.

7. Boas práticas e mitigação

- Usar switch com proteção ARP (Dynamic ARP Inspection).
- Ativar HTTPS e DNSSEC sempre que possível.
- Monitorizar pacotes ARP suspeitos com ferramentas como arpwatc.
- Configurar reservas de IP e tabelas ARP estáticas em redes críticas.

8. Perguntas possíveis (e respostas curtas)

- ■ O que é ARP Spoofing?
→■ Um ataque em que o invasor finge ser outro dispositivo na rede (ex: o gateway).
- ■ O que é DNS Spoofing?
→■ Alterar respostas DNS para redirecionar o utilizador a sites falsos.
- ■ Para que serve o dnsmasq?
→■ Gerir DHCP e DNS local (atribui IPs e resolve nomes).
- ■ Qual é o papel do gateway?
→■ Fazer NAT e ligar a rede local à Internet.
- ■ Como evitar ARP Spoofing?
→■ Usar Dynamic ARP Inspection e HTTPS.
- ■ O que faz o comando arpspoof?
→■ Envia respostas ARP falsas para redirecionar o tráfego.
- ■ O que significa NAT?
→■ Network Address Translation, traduz IPs internos para um IP público.
- ■ Como o atacante faz o cliente acreditar que ele é o gateway?
→■ Enviando respostas ARP falsas com o seu próprio MAC.